Universidade Presbiteriana Mackenzie

GOVERNANÇA E COMPLIANCE EM TI

Prof. Cleórbete Santos

COBIT

Universidade Presbiteriana Mackenzie

Definição

COBIT é um framework (um conjunto de boas práticas) criado pela ISACA para ajudar as empresas a alinhar a tecnologia com os objetivos de negócio.

Em termos simples o COBIT garante que a TI não esteja apenas mantendo a infraestrutura tecnológica, mas criando valor para a empresa crescer.

COBIT 2019

Control Objectives for Information and Related Technologies

5 Princípios Fundamentais (COBIT 5)

1. Atender às Necessidades dos Stakeholders: O foco é quem manda (acionistas, clientes). A TI deve entregar o que eles precisam;
2. Cobrir a Organização de Ponta a Ponta: A governança de TI não fica só no "departamento de informática"; ela permeia toda a empresa;
3. Aplicar um Framework Único e Integrado: O COBIT serve como um "guarda-chuva" que se conecta a outros padrões (como ITIL para serviços ou ISO para segurança);
4. Habilitar uma Abordagem Holística: Considera processos, pessoas, cultura e infraestrutura de forma conjunta;
5. Distinguir a Governança da Gestão:

5.1 Governança: Avalia, direciona e monitora (Estratégia);
5.2 Gestão: Planeja, constrói, executa e monitora (Operação).

Necessidades x COBIT

- A Diretoria quer: redução de custos, segurança e lucro;

- A TI quer: servidores novos, softwares modernos e estabilidade.

O COBIT traduz essas necessidades em objetivos de governança e gestão, organizados em 05 domínios, garantindo que os riscos sejam gerenciados e que o investimento em tecnologia não seja desperdiçado.

I. Domínio de Governança

EDM — Avaliar, Direcionar e Monitorar (Evaluate, Direct and Monitor)

Estes 5 objetivos são de responsabilidade da Alta Gestão/Diretoria.

EDM01: Framework de Gestão e Governança Assegurado.
EDM02: Benefícios Realizados (Valor para o negócio).
EDM03: Otimização de Riscos Assegurada.
EDM04: Otimização de Recursos Assegurada.
EDM05: Transparência para as Partes Interessadas Assegurada.

II. Domínios de Gestão

1. APO — Alinhar, Planejar e Organizar (Align, Plan and Organize)

Focado na estratégia, organização e planejamento da TI (14 objetivos).

APO01: Framework de Gestão de TI Gerenciado.
APO02: Estratégia Gerenciada.
APO03: Arquitetura Corporativa Gerenciada.
APO04: Inovação Gerenciada.
APO05: Portfólio Gerenciado.
APO06: Orçamento e Custos Gerenciados.
APO07: Recursos Humanos Gerenciados.
APO08: Relacionamentos Gerenciados.
APO09: Acordos de Serviço Gerenciados (SLAs).
APO10: Fornecedores Gerenciados.
APO11: Qualidade Gerenciada.
APO12: Risco Gerenciado.
APO13: Segurança Gerenciada.
APO14: Dados Gerenciados.

II. Domínios de Gestão (Continuação)

2. BAI — Construir, Adquirir e Implementar (Build, Acquire and Implement)

Focado na definição, aquisição e implementação de soluções (11 objetivos).

BAI01: Programas e Projetos Gerenciados.
BAI02: Definição de Requisitos Gerenciada.
BAI03: Identificação e Construção de Soluções Gerenciadas.
BAI04: Disponibilidade e Capacidade Gerenciadas.
BAI05: Mudança Organizacional Gerenciada.
BAI06: Mudanças de TI Gerenciadas.
BAI07: Aceite e Transição de Mudança de TI Gerenciados.
BAI08: Conhecimento Gerenciado.
BAI09: Ativos Gerenciados.
BAI10: Configuração Gerenciada.
BAI11: Projetos Gerenciados.

II. Domínios de Gestão (Continuação)

3. DSS — Entregar, Servir e Suportar (Deliver, Service and Support)

Focado na entrega operacional e suporte técnico (6 objetivos).

DSS01: Operações Gerenciadas.
DSS02: Requisições de Serviço e Incidentes Gerenciados.
DSS03: Problemas Gerenciados.
DSS04: Continuidade Gerenciada.
DSS05: Serviços de Segurança Gerenciados.
DSS06: Controles de Processos de Negócio Gerenciados.

II. Domínios de Gestão (Continuação)

4. MEA — Monitorar, Avaliar e Medir (Monitor, Evaluate and Assess)

Focado no monitoramento da conformidade e performance (4 objetivos).

MEA01: Monitoramento de Desempenho e Conformidade Gerenciados.
MEA02: Sistema de Controle Interno Gerenciado.
MEA03: Conformidade com Requisitos Externos Gerenciada.
MEA04: Garantia (Asseguração) Gerenciada.

EXEMPLO:
AMEAÇA DE ATAQUE DE RANSOMWARE

Exemplo

1. Identificação do Risco (Baseado no APO12.01*)

Ao coletar dados é identificado que sistemas legados não recebem atualizações há dois anos.

Ação: Registrar que há uma vulnerabilidade alta.

Pergunta do COBIT: "Qual o impacto financeiro e reputacional se os dados forem criptografados por atacantes?"

* APO12: Risco Gerenciado.

Exemplo

2. Análise e Avaliação (Baseado no APO12.02)

Descobre-se que a probabilidade é alta (devido aos sistemas antigos) e o impacto é crítico (interrupção de serviços da empresa).

Decisão de Governança (EDM03*): A diretoria avalia se aceita esse risco ou se investe para mitigá-lo. Eles decidem que o risco é inaceitável.

* EDM03: Otimização de Riscos Assegurada.

Exemplo

3. Resposta ao Risco (Baseado no APO12.03)

Para mitigar o risco, a empresa aciona outros objetivos do COBIT:

- BAI06 (Gerenciar Mudanças): Planejar a atualização imediata dos servidores;
- DSS05 (Serviços de Segurança): Implementar autenticação de dois fatores e novos firewalls;
- DSS04 (Gerenciamento de Continuidade): Garantir que os backups estejam offline e testados.

Exemplo

4. Monitoramento e Reporte (Baseado no APO12.06)

É criado um painel (Dashboard) para a diretoria mostrando quantos ataques foram bloqueados no mês e o status de atualização das máquinas.

Conexão com MEA01*: Monitorar se os controles de segurança estão realmente sendo executados pela equipe.

* MEA01: Monitoramento de Desempenho e Conformidade Gerenciados.

Universidade Presbiteriana Mackenzie

ITIL

Definição

A ITIL é uma biblioteca de melhores práticas para gerenciamento dos serviços de TI e melhoria do suporte de TI e dos níveis de serviço.

No ITIL a TI não entrega serviços, entrega valor.

4 Dimensões do ITIL

- Organizações e Pessoas: Cultura, competências e comunicação;

- Informação e Tecnologia: O conhecimento e as ferramentas necessárias;

- Parceiros e Fornecedores: Quem ajuda de fora (Cloud, consultorias, etc);

- Fluxos de Valor e Processos: Como as atividades se integram.

Exemplos de práticas do ITIL

Prática	O que faz	Exemplo
Central de Serviços (Service Desk)	Ponto único de contato	E-mail, telefone ou site
Gestão de Incidentes	Restaura o serviço o mais rápido possível	Queda do sinal de Internet
Gestão de Problemas	Investiga a causa raiz dos problemas	Por que o sinal da Internet caiu?
Gestão de Mudanças	Garante que as alterações não causem desastres	Atualizar o sistema na madrugada do sábado para o domingo
Gestão de Ativos	Controla o inventário	Onde está o laptop XYZ?

Universidade Presbiteriana Mackenzie

COBIT x ITIL

COBIT x ITIL

COBIT e ITIL não são concorrentes.

As empresas usam o COBIT para governar e o ITIL para operar.

O COBIT diz: "Precisamos garantir que os dados estejam seguros e os riscos controlados“, ou seja, o quê fazer.

O ITIL diz "Para garantir a segurança, vamos criar um processo de Gestão de Mudanças e um Service Desk para monitorar acessos.“, ou seja, o como fazer.

Universidade Presbiteriana
Mackenzie

Faculdade de
Computação e Informática